MAIDAR

Human Risk Simulation Platform

Founder Product Document – Internal Use Only

1. Executive Summary

Maidar is a Human Risk Intelligence Platform.

It is not a phishing template tool.

It is not a click-rate dashboard.

It is not a generic awareness system.

Maidar measures, predicts, explains, and reduces human cyber risk inside organizations.

Phishing simulation is one input signal within a larger human risk model.

The core innovation of Maidar is:

“Scenario-aware, explainable, deterministic Human Risk Scoring.”

Risk is calculated per employee, per scenario, using a mathematical model.

2. Vision

Organizations currently:

- Treat employees equally in training.
- Run generic phishing campaigns.
- Measure only click rates.
- Cannot quantify “human risk exposure.”
- Cannot explain why someone is high risk.
- Cannot prioritize remediation scientifically.

Maidar solves this by:

- Quantifying risk per employee.
- Differentiating Likelihood and Impact.

- Making risk contextual to scenario type.
- Producing explainable outputs.
- Providing executive-level visibility.

The long-term positioning is “Human Risk Intelligence as a Service (HRaaS)”; not phishing-as-a-service.

3. What We Are Building

Maidar is a platform that measures human cyber risk inside organizations.

It does this by:

1. Taking employee profile data
2. Taking a phishing scenario type
3. Calculating:
    - How likely that employee is to fall for that scenario
    - How damaging it would be if they did
4. Multiplying those two numbers
5. Producing a final risk score from 0–100

That’s the core engine.

Everything else (UI, dashboards, AI scenario generation) sits around that engine.

4. Legal and Regulatory Compliance

All system design must comply with:

UAE Federal Decree-Law No. 45 of 2021 on the Protection of Personal Data

This is non-negotiable.

4.1. Core Data Protection Principles

4.1.1. Purpose Limitation

Employee data is processed strictly for:

- Security risk assessment

- Organizational cyber resilience

No secondary commercial use.

4.1.2. Data Minimization

Only required attributes are collected:

- Age range (not full DOB)
- Gender (optional)
- Languages
- Technical literacy score
- Department
- Seniority
- Job title

No unnecessary personal data.

4.1.3. Data Residency

Default hosting:

- UAE-based infrastructure

Tenant-level data isolation required.

4.1.4. Access Control

Role-based access control:

- Platform Super Admin
- Tenant Admin
- Analyst

No cross-tenant visibility.

4.1.5. Encryption

- AES-256 at rest
- TLS 1.2+ in transit <<< prefer TLS 1.3, but lets discuss

4.1.6. Audit Logging

Log:

- Data imports
- Simulation launches
- Score recalculations
- Exports
- Deletions

4.1.7. Right to Erasure

Tenant must be able to:

- Delete employee
- Export employee data
- Remove historical logs if required

Privacy-first architecture is mandatory.

5. System Architecture

Maidar consists of five main components:

5.1. Employee Intelligence Engine

Handles:

- CSV upload
- Directory integration (Azure AD, Google Workspace, LDAP)
- Attribute normalization
- Technical literacy survey ingestion

5.2. Risk Scoring Engine (Core Engine)

Computes:

- Likelihood L(e,s)
- Impact I(e,s)

- HumanRisk(e,s)

Deterministic, versioned, scenario-aware.

5.3. AI Scenario Lab

Allows admin to:

- Generate phishing simulations
- Choose scenario category
- Choose language
- Customize tone
- Preview simulation
- Save templates

AI personalization logic must support:

- Name
- Role
- Language
- Cultural context

5.4. Simulation Engine

- Sends simulated emails
- Tracks interaction
- Logs outcomes
- Updates behavioral history (future phase)

5.5. Analytics & Executive Dashboard

Displays:

- Overall Company Risk
- Risk by department
- Risk by seniority
- Risk by age group

- Risk by language
- Top 10/20/50 highest-risk employees
- Risk trends over time

Executive-readable. No technical jargon.

6. Human Risk Score (v1)

Risk is scenario-aware.

Each employee e receives:

- Likelihood L(e,s)
- Impact I(e,s)

Final score:

HumanRisk(e,s) = round(100 × L(e,s) × I(e,s))

All components clamped to [0,1].

Multiplicative model is intentional:

- High likelihood + low impact ≠ catastrophic
- Low likelihood + high impact ≠ catastrophic
- Only when both are high does risk become critical

7. Inputs

We are not collecting full personal data. Only risk-related attributes.

For each employee:

Risk (Likelihood) Inputs

- Age range (not full DOB)
- Gender
- Languages spoken
- Technical literacy score (0–10 survey result)

Impact Inputs

- Seniority level
- Department

- Job title (used for role classification)

Scenario Inputs

When running a simulation, we define:

- Scenario category:
    - BEC (invoice/wire fraud)
    - CREDENTIALS (login harvest)
    - DATA (sensitive info request)
    - MALWARE (attachment/install lure)
- Scenario language

8. Maidar Human Risk Score

Overview

Each employee e gets:

- **Likelihood** $L(e, s)$= how likely they are to fall for a given scenario s
- **Impact** $I(e, s)$= how damaging it would be *for this scenario type* if they fall for it

Final:

$$\text{HumanRisk}(e, s) = \text{round}(100 \times L(e, s) \times I(e, s))$$

All components are clamped to $[0, 1]$.

8.1. Inputs (employee profile)

Risk-side inputs (Likelihood)

- age_range (enum)
- gender (enum)
- languages (array of language codes/names)
- technical_literacy (int 0–10)

Impact-side inputs

- seniority (enum)
- department (enum) and/or job_title (string)

- (Optional in v1) role_tags derived from job_title patterns (recommended)

Scenario inputs

- scenario.category ∈ {BEC, CREDENTIALS, DATA, MALWARE} *(you can rename labels; keep same semantics)*
- scenario.language (language code/name)

8.2. Likelihood $L(e, s)$

8.2.1. Normalize sub-factors to $[0, 1]$

A) Technical literacy risk

Given TL in $[0, 10]$:

$$TL_risk = 1 - \frac{TL}{10}$$

B) Age modifier A

Use fixed lookup:

Age Range	A
18-25	0.70
26-35	0.55
36-50	0.45
51-60	0.6
60+	0.75

C) Gender modifier G

Gender	G
Male	0.5
Female	0.55

D) Language match modifier $LM(e, s)$(scenario-dependent)

Let scenario.language be the language used in the scenario.

- If scenario.language ∈ employee.languages → Full match: 0.50
- Else if employee speaks a "close" variant (optional mapping) → Partial match: 0.60

- Else → Mismatch: 0.70

(Keep this simple in v1: full match vs mismatch; partial is optional.)

8.2.2. Likelihood formula

Weights reflect evidence strength (TL strongest; gender weakest):

$$L(e,s) = 0.40\, TL_risk + 0.25\, A + 0.20\, LM(e,s) + 0.15\, G$$

Clamp $L$to $[0, 1]$.

8.3. Impact $\boldsymbol{I(e,s)}$ -- Scenario-Aware

Impact is computed as a blend of:

- seniority impact $S(e)$
- scenario-specific role/department impact $R(e,s)$

$$I(e,s) = \alpha_{cat(s)}\, S(e) + (1 - \alpha_{cat(s)})\, R(e,s)$$

8.3.1. Seniority impact $\boldsymbol{S(e)}$

Seniority	S
Intern	0.2
Junior	0.35
Mid	0.55
Senior	0.75
Executive	1.00

8.3.2. Scenario categories + alpha

These are the "how much seniority matters for this scenario type" weights:

Scenario Category	Meaning	α (seniority weight)
BEC	Invoice/wire/payment request/CEO fraud	0.70
Credentials	SSO/VPN/Credential Harvest	0.2
Data	HR/Document request/sensitive data Disclosure	0.30

Malware	Attachment/macro/drive-by install/update lure	0.40

8.3.3. Scenario-specific role impact $R(e, s)$

You will store one role-impact lookup per category. Start with department-first (simple). Optionally refine with job_title tags.

A) R_BEC (invoice/wire fraud impact)

Dept/Role	R_BEC
Finance/Accounting	1.00
Procurement/Purchasing	0.85
Executive Office/Exec. Assistants	0.80
Legal/Contracts	0.70
HR	0.65
IT/Security	0.55
Sales/Marketing/Operations/Others	0.50

B) R_CREDENTIALS (credential theft impact)

Dept/Role	R_CREDENTIALS
IT Security/IT Admin	1.00
General IT	0.85
Finance/Legal/HR	0.75
Operations	0.65
Sales/Marketing/Other	0.55

C) R_DATA (data/PII disclosure impact)

Dept/Role	R_DATA
HR	1.00
Legal/Compliance	0.90
Finance	0.85
Customer Support/Sales Operations	0.80
Operations	0.65
IT/Security	0.6
Marketing/Other	0.55

D) R_MALWARE (malware/ransomware lure impact)

Dept/Role	R_MALWARE
IT Admin/Security	0.95
General IT	0.85
Operations	0.80
Finance/HR/Legal	0.75
Sales/Marketing	0.65
Other Depts	0.55

8.4. Final score + bands

$$Score(e,s) = round(100 \times L(e,s) \times I(e,s))$$

Suggested bands (locked for now):

- 0–24 Low
- 25–49 Medium
- 50–74 High
- 75–100 Critical

8.5. Explainability output

For every score, return a breakdown:

Likelihood drivers

- TL_risk contribution = $0.40 \times TL_risk$
- Age contribution = $0.25 \times A$
- LangMatch contribution = $0.20 \times LM$
- Gender contribution = $0.15 \times G$

Impact drivers

- alpha used for this scenario category
- Seniority contribution = $\alpha \times S$
- RoleImpact contribution = $(1 - \alpha) \times R$

9. Core Product Rules

Maidar must never:

- Be a generic phishing template sender.
- Rely only on click-rate metrics.
- Use random scoring.
- Hide formula logic.
- Ignore UAE data laws.

Maidar must always:

- Be deterministic.
- Be explainable.
- Be scenario-aware.
- Be privacy-first.
- Be modular and scalable.

10. Development Philosophy

This is a math-first platform.

If the scoring engine is weak, everything collapses.

UI, AI, simulations: All are layers around the scoring core.

The Risk Engine is the heart of Maidar.

11. Core Problem Maidar Solves

Organizations today:

- Treat employees equally in security training
- Run generic phishing campaigns
- Lack explainable risk scoring
- Cannot quantify human risk at executive level
- Cannot predict which employees are high likelihood AND high impact

Maidar solves this by:

1. Building a quantified Human Risk Score per employee

2. Breaking risk down by:
    - Department
    - Seniority
    - Age group
    - Gender
    - Language
    - Technical literacy
3. Explaining *why* an employee is high risk
4. Generating AI-powered simulated scenarios tailored to the employee

12. Core Architecture Overview

Maidar consists of 5 main engines:

1. **Employee Intelligence Engine**
    - Imports employee data (CSV or directory integration)
    - Collects demographic + professional metadata
    - Collects technical literacy survey data
2. **Risk Scoring Engine**
    - Calculates Likelihood Score (0–100)
    - Calculates Impact Score (0–100)
    - Combines into Human Risk Score (0–100)
    - Dynamic scenario-based modifiers
3. **AI Scenario Lab**
    - Generates phishing simulations
    - Generates legitimate comparison emails
    - Customizes by language, role, department, literacy level
    - Simulates AI personalization logic
4. **Simulation Engine**
    - Sends simulated attacks

    - Tracks interaction
    - Logs behavioral outcomes
5. **Analytics & Executive Dashboard**
    - Organizational risk health
    - Top 10 / 20 / 50 riskiest employees
    - Risk distribution by segment
    - Explainability breakdown